

Tier 4. Module 7 - Secure Software Development and Integration

Topic 11. Homework - Security in container and cloud environments

Laboratory report

1. Pipeline execution for Docker-bad

The screenshot shows a GitHub Actions workflow named 'upd pipeline'. It was created 17 seconds ago by 'Matajur' and finished just now. It is for commit '00513622' on the 'main' branch. The pipeline has 3 jobs and 0 tests. The jobs are: 'lint' (using 'hadolint', status: warning), 'scan' (using 'trivy', status: success), and 'audit' (using 'dockle', status: success). The 'lint' job is highlighted with a warning icon.

1.1 Hadolint

```
/mnt/Dockerfile:4 DL3008 warning: Pin versions in apt get install. Instead of `apt-get install <package>` use `apt-get instal
l <package>=<version>`
/mnt/Dockerfile:4 DL3009 info: Delete the apt lists (/var/lib/apt/lists) after installing something
/mnt/Dockerfile:4 DL3015 info: Avoid additional packages by specifying `--no-install-recommends`
/mnt/Dockerfile:12 DL3020 error: Use COPY instead of ADD for files and folders
Cleaning up project directory and file based variables
ERROR: Job failed: exit code 1
```

Hadolint is linter that focuses on Dockerfile syntax and "best practices".

Even though one critical issue was found related to using **ADD** instead of **COPY** and the scanner exited with status code 1, the task only showed a warning because **allow_failure: true** is set and the pipeline will continue to run even if issues are found.

1.2 Trivy

```
Report Summary

| Target | Type | Misconfigurations |
| Dockerfile | dockerfile | 4 |

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)
Dockerfile (dockerfile)
=====
Tests: 27 (SUCCESSSES: 23, FAILURES: 4)
Failures: 4 (UNKNOWN: 0, LOW: 2, MEDIUM: 0, HIGH: 2, CRITICAL: 0)
AVD-DS-0002 (HIGH): Specify at least 1 USER command in Dockerfile with non-root user as argument

Running containers with 'root' user can lead to a container escape situation. It is a best practice to run containers as non-root users, which can be done by adding a 'USER' statement to the Dockerfile.
See https://avd.aquasec.com/misconfig/ds002

AVD-DS-0005 (LOW): Consider using 'COPY .' command instead of 'ADD .' command

You should use COPY instead of ADD unless you want to extract a tar file. Note that an ADD command will extract a tar file, which adds the risk of Zip-based vulnerabilities. Accordingly, it is advised to use a COPY command, which does not extract tar files.
See https://avd.aquasec.com/misconfig/ds005

Dockerfile:12

12 [ ADD . /app

AVD-DS-0026 (LOW): Add HEALTHCHECK instruction in your Dockerfile

You should add HEALTHCHECK instruction in your docker container images to perform the health check on running containers.
See https://avd.aquasec.com/misconfig/ds026

AVD-DS-0029 (HIGH): '--no-install-recommends' flag is missed: 'apt-get update && apt-get install -y curl'

'apt-get' install should use '--no-install-recommends' to minimize image size.
See https://avd.aquasec.com/misconfig/ds029

Dockerfile:4

4 [ RUN apt-get update && apt-get install -y curl
```

Trivy is vulnerability scanner that focuses on known CVEs (Common Vulnerabilities and Exposures) in packages and configuration missteps.

Despite detecting two high vulnerabilities, the system did not display any warnings even when `allow_failure: false` was set because no severity threshold was set in the pipeline.

1.3 Dockle

```

dockle-report.json x +
{
  "summary": {
    "fatal": 2,
    "warn": 1,
    "info": 4,
    "skip": 0,
    "pass": 9
  },
  "details": [
    {
      "code": "CIS-DI-0009",
      "title": "Use COPY instead of ADD in Dockerfile",
      "level": "FATAL",
      "alerts": [
        "Use COPY : /bin/sh -c #(nop) ADD dir:c2e96daea41ed7476e0672718c330a71b13897742b6f9c2fd98c4fc1abe7822d in /app "
      ]
    },
    {
      "code": "DKL-DI-0005",
      "title": "Clear apt-get caches",
      "level": "FATAL",
      "alerts": [
        "Use 'rm -rf /var/lib/apt/lists' after 'apt-get install|update' : /bin/sh -c apt-get update \u0026\u0026 apt-get install -y curl"
      ]
    },
    {
      "code": "CIS-DI-0001",
      "title": "Create a user for the container",
      "level": "WARN",
      "alerts": [
        "Last user should not be root"
      ]
    },
    {
      "code": "CIS-DI-0005",
      "title": "Enable Content trust for Docker",
      "level": "INFO",
      "alerts": [
        "export DOCKER_CONTENT_TRUST=1 before docker pull/build"
      ]
    },
    {
      "code": "CIS-DI-0006",
      "title": "Add HEALTHCHECK instruction to the container image",
      "level": "INFO",
      "alerts": [
        "not found HEALTHCHECK statement"
      ]
    }
  ]
}
```

Dockle is a linter for images that focuses on security "Best Practices" for the final image (CIS Benchmarks). In our case it has the same pipeline configuration problems as Trivy.

2. Pipeline execution for Docker-bad

upd Dockerfile

Deleted

Passed

Created 25 seconds ago by Matajur, finished just now

For commit 42381aa7

In main

latest

branch

3 jobs

2 minutes 12 seconds, queued for 1 seconds

Pipeline

Jobs 3

Tests 0

lint

hadolint

scan

trivy

audit

dockle

2.1 Hadolint

```
latest: Pulling from hadolint/hadolint
14ae1c277c18: Pulling fs layer
14ae1c277c18: Download complete
14ae1c277c18: Pull complete
Digest: sha256:27086352fd5e1907ea2b934eb1023f217c5ae087992eb59fde121dce9c9ff21e
Status: Downloaded newer image for hadolint/hadolint:latest
Cleaning up project directory and file based variables
Job succeeded
```

00:01

No more critical issues or warnings, exit code 0.

2.2 Trivy

Report Summary

Target	Type	Misconfigurations
Dockerfile	dockerfile	0

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

Cleaning up project directory and file based variables
Job succeeded

No security findings detected, exit code 0.

2.3 Dockle

```
dockle-report.json x +
{
  "summary": {
    "fatal": 0,
    "warn": 0,
    "info": 2,
    "skip": 0,
    "pass": 14
  },
  "details": [
    {
      "code": "CIS-DI-0005",
      "title": "Enable Content trust for Docker",
      "level": "INFO",
      "alerts": [
        "export DOCKER_CONTENT_TRUST=1 before docker pull/build"
      ]
    },
    {
      "code": "CIS-DI-0008",
      "title": "Confirm safety of setuid/setgid files",
      "level": "INFO",
      "alerts": [
        "setuid file: urwxr-xr-x usr/bin/chfn",

```

Only two warnings of Info level, exit code 0.

Results comparison table

Instrument	Types of risks (Docker-bad)	How fixed (Docker-good)	Violated SSDLC principles/best practices	Criticality
Hadolint	Use of ADD	ADD replaced by nothing, which can be still risky with no automatic context copy	Least Privilege / Attack Surface Minimization	High
Hadolint	No versions Pinned in apt get install	apt-get install -y --no-install-recommends, but still no versions pinned	Supply Chain Vulnerability / Immutability	Medium
Hadolint	Too big image size / attack surface	apt-get install -y --no-install-recommends apt-get clean && rm -rf /var/lib/apt/lists/*	Attack Surface Minimization	Low

Instrument	Types of risks (Docker-bad)	How fixed (Docker-good)	Violated SSDLC principles/best practices	Criticality
Trivy	Running containers with 'root' user	<code>RUN useradd -m -s /bin/bash safeuser USER safeuser</code>	Least Privilege	High
Trivy	Too big image size / attack surface	<code>apt-get install -y --no-install-recommends apt-get clean && rm -rf /var/lib/apt/lists/*</code>	Attack Surface Minimization	High
Trivy	Use of ADD	ADD replaced by nothing, which can be still risky with no automatic context copy	Least Privilege / Attack Surface Minimization	Low
Dockle	Use of ADD	ADD replaced by nothing, which can be still risky with no automatic context copy	Least Privilege / Attack Surface Minimization	High
Dockle	Too big image size / attack surface	<code>apt-get install -y --no-install-recommends apt-get clean && rm -rf /var/lib/apt/lists/*</code>	Attack Surface Minimization	High
Dockle	Running containers with 'root' user	<code>RUN useradd -m -s /bin/bash safeuser USER safeuser</code>	Least Privilege	Medium

Notes:

- Different tools give different criticality for the same issues.
- Good Dockerfiles uses `debian:12.5-slim` image instead of `ubuntu:22.04`, which is much lighter, therefore smaller attack surface.

Conclusion

Hadolint, Trivy and Dockle were used to cover the Build, Software, and Configuration layers, because each one has its own area of responsibility:

- Hadolint checks the Dockerfile code itself.
- Trivy is a scanner for the actual software and libraries inside.
- Dockle audits the final image structure.

In general, all three tools showed the same problems, but gave them different criticality:

- Using `ADD` instead of `COPY`;

- Running the container as root;
- Not clearing the cache and saving large image.

CI/CD automation moves security checks earlier in the delivery flow and makes them consistent ("fall fast" approach). Every change is built the same way, scanned the same way, and blocked the same way if it violates security gates. This reduces human error and shortens the time between introducing a vulnerability and detecting it.

For a production environment, it's required to fix at least all high and critical vulnerabilities, but that's only half the battle. The actual pipeline configuration, regardless of whether the Dockerfile configuration is good or bad, only issues warnings in the logs. In a production environment, it should display these warnings and stop the deployment if issues are found at a threshold level (usually: High).